

Step by step process

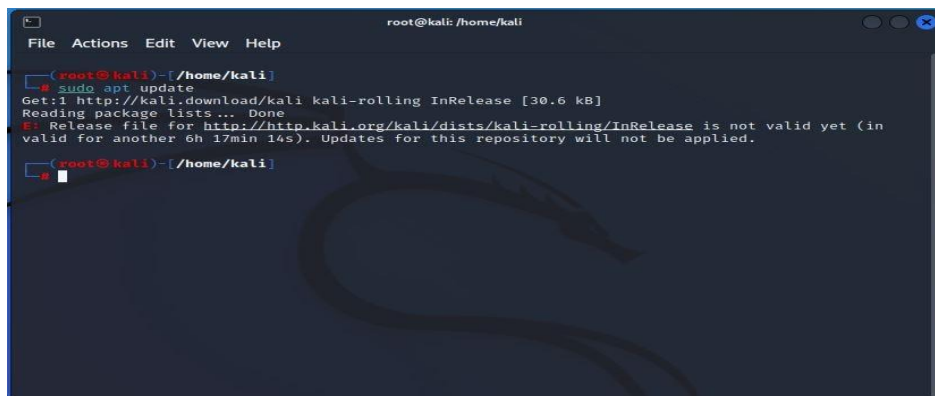
This project utilizes Nessus to proactively identify security weaknesses and misconfigurations across network infrastructure and web applications before malicious actors can exploit them. By leveraging Nessus's extensive library of updated plugins, the system conducts automated unauthenticated and credentialed scans to discover active hosts, map open ports, and analyze running services against known CVE databases

Nessus Downloading and Installing

1: Open Kali terminal.

Run:

sudo apt update



```
root@kali: /home/kali
File Actions Edit View Help
root@kali ~# sudo apt update
Get:1 http://kali.download/kali kali-rolling InRelease [30.6 kB]
Reading package lists... Done
E: Release file for http://http.kali.org/kali/dists/kali-rolling/InRelease is not valid yet (in
valid for another 6h 17min 14s). Updates for this repository will not be applied.
root@kali ~#
```

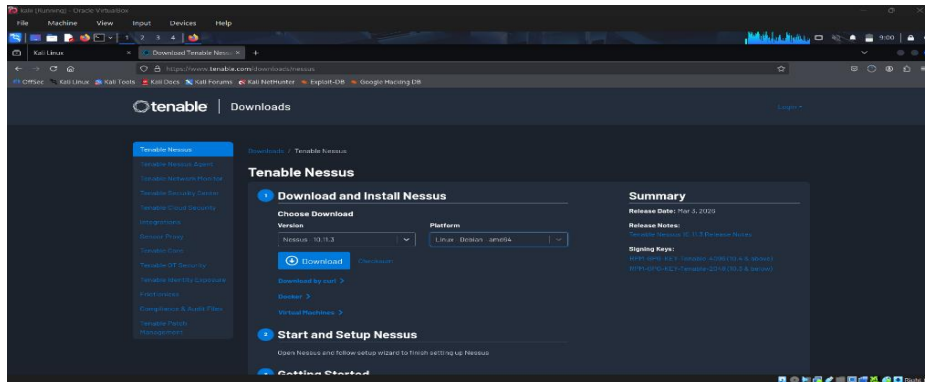
2: Then download Nessus:

Go to browser:

<https://www.tenable.com/downloads/nessus>

Select:

Linux Debian 64 bit



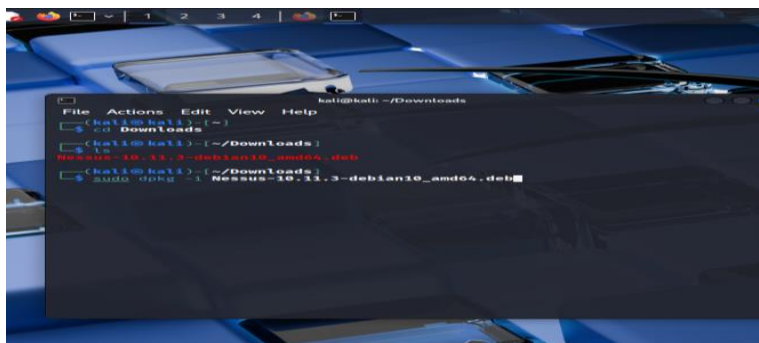
3: Go to Downloads folder

In terminal:

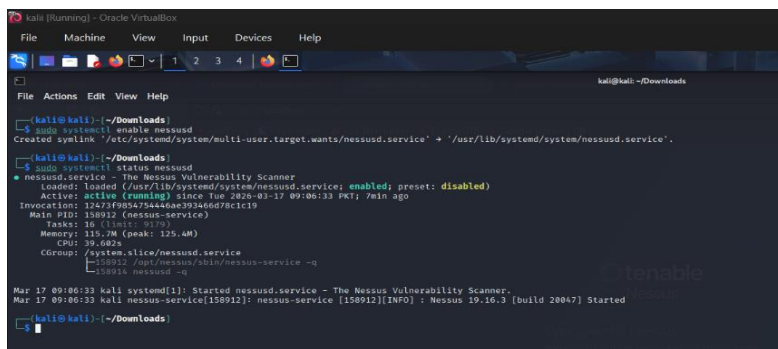
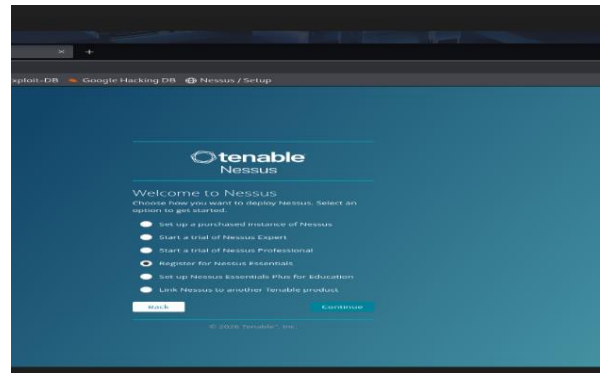
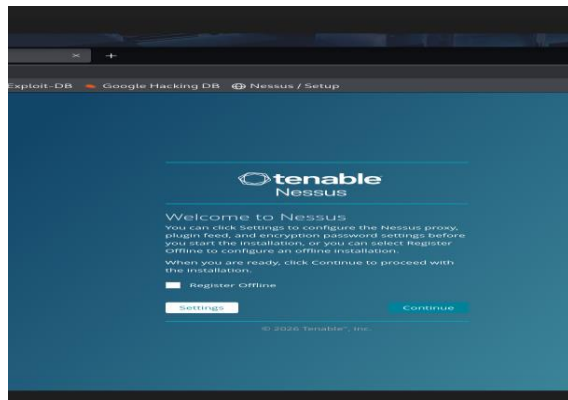
cd Downloads

Install:

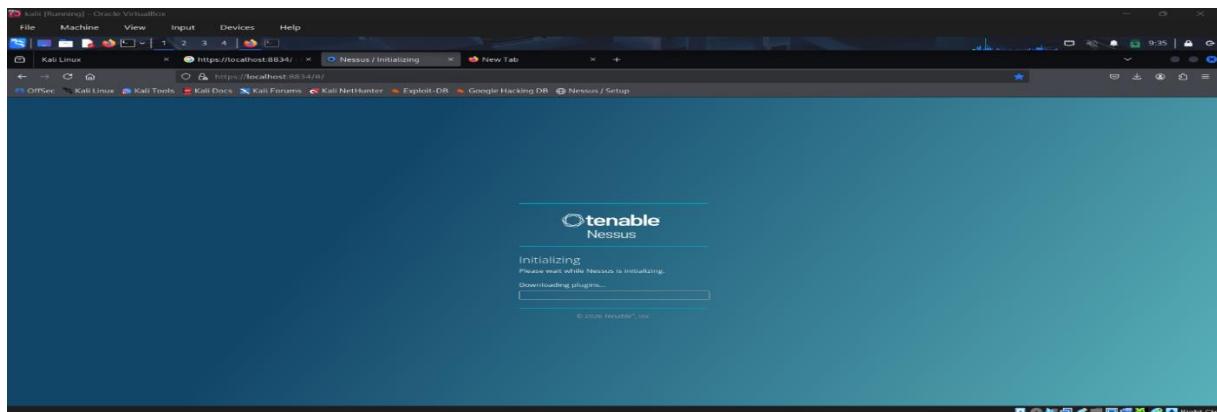
sudo dpkg -i Nessus-10.11.3-debian10_amd64.deb



4: Activate Nessus:

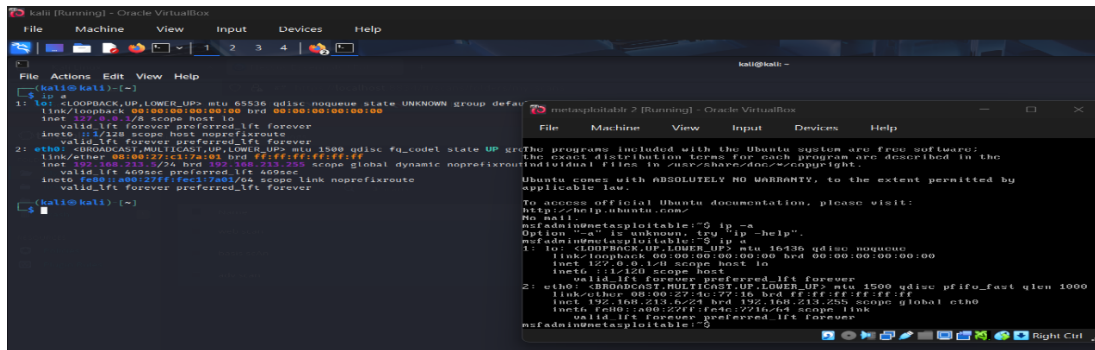


5: Account Creation



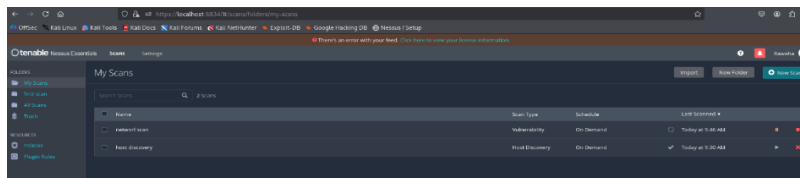
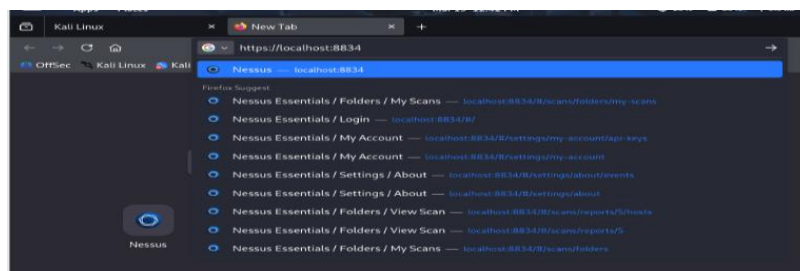
5:Start Metasploitable & Kali

Get IP of both:



6:Open Nessus

<https://localhost:8834>



Nessus Scanning

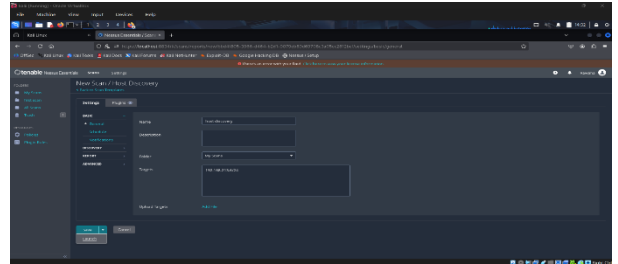
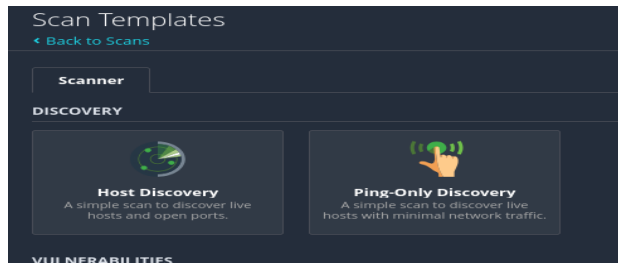
PART 1:

List of live hosts and open ports with explanations.

Network Discovery:

In this lab, Nessus vulnerability scanner was used to perform a network discovery scan. The purpose of this scan was to identify active hosts available in the network.

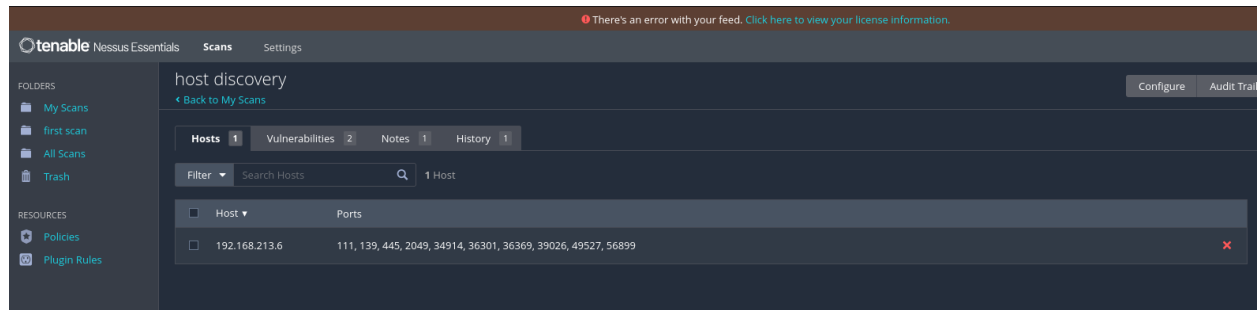
The IP address of the Metasploitable machine was entered as the target.



After launching the scan, Nessus successfully detected the live host in the network.

The scan result showed that the target machine was active and responding.

This confirms that the connection between Kali Linux and Metasploitable was successful.



The discovered host IP address was:

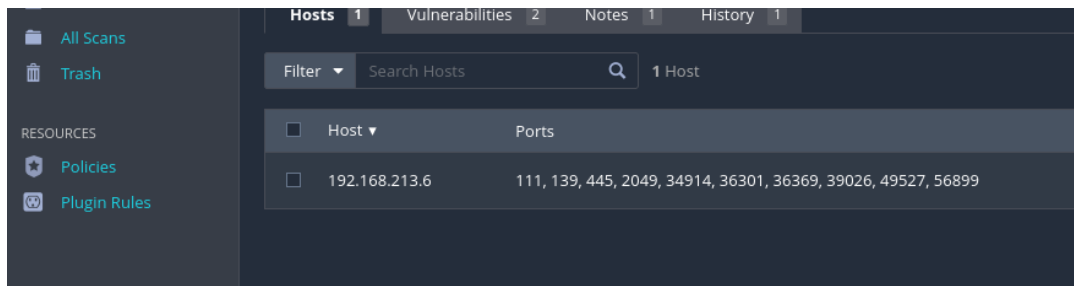
192.168.213.6 This host will be used for further scanning in next parts.

PART 2: Table of Open ports and their functions.

Open Ports and Services

After performing the network discovery scan, a detailed scan was performed to identify open ports and running services on the target machine.

The scan result showed multiple open ports which indicate active services running on the system.



Each port is associated with a specific service. These services may contain vulnerabilities if not properly secured.

The following table shows the detected ports, their services, and functions.

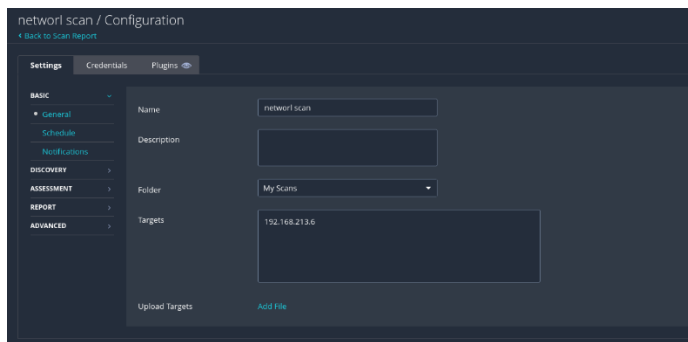
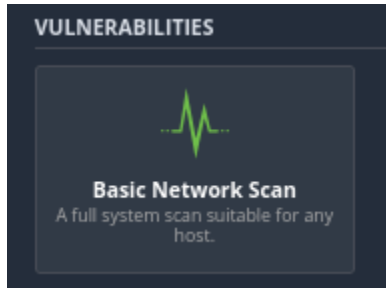
Port	Service	Function
111	RPCBind (Portmapper)	Used in Linux/Unix systems to map RPC services. Helps clients find available network services.
139	NetBIOS Session Service	Used for file/printer sharing in Windows networks (SMB over NetBIOS).
445	SMB (Server Message Block)	Main Windows file sharing protocol. Also used for remote administration.
2049	NFS (Network File System)	Allows file sharing between Linux/Unix systems over network.
34914	Dynamic / Ephemeral Port	Temporary port used by applications (often RPC or NFS related).
36301	Dynamic / Ephemeral Port	Same as above – used for temporary communication.
36369	Dynamic / Ephemeral Port	Likely tied to RPC/NFS services.
39026	Dynamic / Ephemeral Port	Temporary client-server communication.
49527	Dynamic Port (Windows RPC)	Used by Windows for RPC communication.
56899	Dynamic Port	Random high port used by system or application.

These open ports will be analyzed further in vulnerability scanning.

PART 3: Detailed analysis of at least 5 vulnerabilities (critical/high).

Vulnerability Scan and Analysis

A vulnerability scan was performed using Nessus to identify security weaknesses in the target machine (Metasploitable).



The scan detected several critical and high risk vulnerabilities which may allow an attacker to gain unauthorized access to the system.

The following vulnerabilities were found during the scan

A screenshot of the Nessus "Vulnerabilities" page showing a table of detected issues. The table has columns for "Sev", "CVSS", "VPR", "EPSS", "Name", "Family", and "Count". The vulnerabilities are listed with their severity levels and descriptions.

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Canonical Ubuntu Linux SBOL (8.04.x)	General	1
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	3
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
MEDIUM				Apache Tomcat (Multiple Issues)	Web Servers	4
CRITICAL				SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5 *	6.7	0.5006	rlwrap Service Detection	Service detection	1
HIGH	7.5	5.9	0.7714	Samba BadLock Vulnerability	General	1
HIGH	7.2			HPD Shares World Readable	RPC	1
MEDIUM				SSL (Multiple Issues)	General	28
MEDIUM				ISC Bind (Multiple Issues)	DNS	5

1 : Canonical Ubuntu Vulnerability

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)

Description
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.
Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also
<http://www.nessus.org/u73bdb2d2e>

Output
OS : Ubuntu Linux 8.04
Security End of Life : May 9, 2013
Time since Security End of Life (Est.) : >= 12 years
To see debug logs, please visit individual host

Port ▲	Hosts
80 / tcp / www	192.168.213.6

Description:

This vulnerability exists in the Ubuntu package installed on the system. The outdated package may allow attackers to exploit the system remotely.

Impact:

An attacker can gain unauthorized access or execute malicious code.

Solution:

Update Ubuntu packages to the latest version

.

2: VNC Server Password Vulnerability

Hosts 1 Vulnerabilities 70 Remediations 2 Notes 4 History 1

CRITICAL VNC Server 'password' Password

Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution
Secure the VNC service with a strong password.

Output
Nessus logged in using a password of "password".
To see debug logs, please visit individual host

Port ▲	Hosts
5900 / tcp / vnc	192.168.213.6

Description:

The VNC server is configured with weak authentication which allows remote login.

Impact:

An attacker can access the system remotely without proper security.

Solution:

Use strong password and disable VNC if not required.

3: Apache Tomcat Vulnerability

The screenshot shows a Nessus scan result for a vulnerability identified as 'Apache Tomcat AJP Connector Request Injection (Ghostcat)'. The interface includes a top navigation bar with tabs for Hosts, Vulnerabilities (70), Remediations (2), Notes (4), and History (1). The vulnerability is marked as 'CRITICAL'. The description states: 'A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE)'. The solution provided is: 'Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.' A 'See Also' section lists several related Nessus CVE links.

Description:

Apache Tomcat web server contains known security flaws which can be exploited remotely.

Impact:

Attacker can run commands on the server and gain control.

Solution:

Update Apache Tomcat to secure version.

4: SSL Version 2 Enabled

The screenshot shows a Nessus scan result for a vulnerability identified as 'SSL Version 2 and 3 Protocol Detection'. The interface includes a top navigation bar with tabs for Hosts, Vulnerabilities (70), Remediations (2), Notes (4), and History (1). The vulnerability is marked as 'CRITICAL'. The description states: 'The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including: - An insecure padding scheme with CBC ciphers. - Insecure session renegotiation and resumption schemes. An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.'

Description:

Old SSL version is enabled on the server which is not secure.

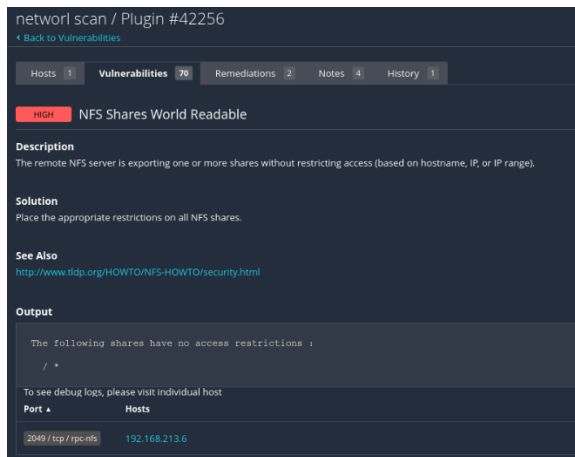
Impact:

Sensitive data can be intercepted by attackers.

Solution:

Disable SSLv2 and enable TLS.

5: NFS Shares World Readable (High)

**Description:**

The Network File System (NFS) service is configured to allow access to shared files without proper restrictions.

Impact:

An attacker can read or modify shared files remotely.

Solution:

Restrict NFS access and allow only trusted IP addresses.

PART 4: Recommendations:

Executive Summary

This lab assignment was performed to understand the process of vulnerability assessment using Nessus vulnerability scanner and Metasploitable virtual machine.

In this practical, a network discovery scan was performed to identify active hosts in the network. After detecting the live host, a detailed scan was conducted to find open ports and running services.

The scan results showed multiple open ports such as RPC, SMB, NFS, and NetBIOS which indicate active services on the target machine. These services may create security risks if not properly configured.

A vulnerability scan was then performed to detect critical and high-risk vulnerabilities. Several vulnerabilities such as Ubuntu package vulnerability, VNC weak password, Apache Tomcat flaw, SSL weakness, Samba vulnerability, and NFS share issue were detected.

Finally, recommendations were provided to secure the system by updating software, disabling unused services, and using strong security configurations.

This lab helped in understanding how ethical hackers identify weaknesses in a system and suggest solutions to improve security.

Conclusions/Recommendations:

In this lab, Nessus was successfully used to perform vulnerability assessment on the Metasploitable machine.

First, the network discovery scan identified the active host in the network. Then, open ports and services were detected which showed that several network services were running.

The vulnerability scan revealed multiple critical and high-risk vulnerabilities such as weak passwords, outdated software, insecure protocols, and misconfigured services.

These vulnerabilities can allow attackers to gain unauthorized access to the system if not fixed. By applying proper security measures such as updating software, disabling unused ports, enabling firewall, and using strong authentication, the system can be secured. This lab provided practical knowledge about vulnerability scanning and the importance of network security.